

Theraptly LMS — Executive Summary

Audit date: 2026-07-05 · Full detail: [SYSTEM-ANALYSIS-REPORT.md](#) · Finding IDs: [FINDINGS-REGISTER.md](#)

The verdict in one paragraph

Theraptly is a capable, well-built product that is **not yet ready to make a HIPAA compliance claim or to scale beyond one server** — and both of those are fixable with focused work, not a rewrite. The engineering fundamentals are sound: the team has already closed a full round of security bugs, the code is clean and typed, and the risky parts (payments, SQL, rich-text rendering, file access) are handled correctly. The problems are **structural and concentrated**: the system doesn't yet keep the compliance records HIPAA requires, it sends and stores sensitive health information in ways that need to change, it can silently stop sending compliance reminders after a restart, and its whole design assumes a single machine. The requested split of the codebase into a separate frontend and backend is the right move — it is also the cleanest way to fix the compliance and scaling problems at the same time.

What's genuinely good (protect these)

- The team already found and fixed **12 prior security vulnerabilities** — this is a codebase that has been stress-tested once.
- Payments (Stripe), database access, and the rich-text editor are all implemented safely.
- Sensitive health data currently flows only to Google's HIPAA-eligible AI service, not the consumer one — the right boundary is already in place.
- Code quality is high: strong test coverage on core logic, no debug leftovers, strict typing.

The 8 things that must change before scaling or selling to healthcare buyers

Each is individually a launch-blocker for a HIPAA product. None requires a rewrite.

#	Problem	Why it matters	Effort
1	No audit log (F-001)	HIPAA legally requires a record of who accessed which health data when. Today nothing is recorded durably.	Medium
2	Health data sent to Google before it's checked, and stored in raw form (F-002, F-003)	The main course-creation flow skips the safety scan entirely; detected health info is saved verbatim.	Medium
3	No backups (F-004)	A single disk failure loses every customer's data permanently.	Small (infra)
4	Compliance reminders can silently stop (F-005)	Reminder and escalation emails only run if a specific admin page has been opened since the last restart; deadline emails can quietly cease.	Small
5	Two customers' data can leak across the tenant boundary (F-009, F-010)	Two specific screens return another organization's staff records and quiz answer keys.	Small

#	Problem	Why it matters	Effort
6	A Google API key is compiled into the public website (F-008)	If populated, it's readable by anyone. Currently unused but present in every build.	Small
7	Data isn't encrypted at rest (F-025)	HIPAA expects stored health data to be encrypted; today it isn't, and document text is stored in plain form.	Medium (infra)
8	The system runs heavy work inside the website process on one server (F-015, F-016)	Document processing and AI generation block user requests and force a large memory footprint; it can't scale out.	Large (this is the split)

The two projects this implies

1. **A compliance & safety hardening sprint** (items 1–7 above, plus security headers and rate limits) — a few weeks of focused work that takes the product from "good code" to "defensible for a healthcare buyer." Most items are small; audit logging, backups, and encryption-at-rest are the substantive ones.
2. **The frontend/backend split** (item 8) — the larger effort you asked us to document. The frontend stays as Next.js; a new backend service owns the database, health data, payments, and AI work; a separate always-on worker service runs the background jobs and reminders. This removes the single-server ceiling **and** draws a clean line around the sensitive data — the frontend can no longer touch the database or the AI keys directly, which is exactly what a compliance auditor wants to see. Full plans are in the [rebuild documentation](#).

Risk if nothing changes

- **Compliance:** the product cannot honestly pass a HIPAA or SOC 2 audit today (missing audit trail, backups, encryption at rest, and PHI-handling controls).
- **Reliability:** one server with no backups and reminder emails that can silently stop is a data-loss and missed-deadline incident waiting to happen.
- **Security:** the two tenant-leak bugs are live and exploitable by any admin who obtains another org's record ID.
- **Scale:** the current design tops out at one instance; growth in documents, videos, or concurrent users will hit a memory and throughput wall.

None of these is a surprise for a 0.1.0 product moving fast — and the codebase is in good enough shape that fixing them is a matter of disciplined execution against the plan, not a restart.